Gestión de Seguridad de la Información

Docente:
Cesar Varela M
Cesar.varela@correoaiep.cl

¡Escanéeme!

Presentación del Programa

Objetivo de la clase

Explicar los fundamentos de la seguridad de la información, en base a la triada de la información

Contenidos de la Clase

- Principios Básicos de la Seguridad
- ¿Qué es la Seguridad de la Información?
- ¿Qué es la Ciberseguridad o Seguridad Informática?
- Amenazas Actuales Ciberseguridad
  - contra quien nos enfrentamos?

¿Qué es la Seguridad de la Información?

Para empezar a hablar de la seguridad de la información debemos comenzar por preguntarnos y definir qué es la información.

La información no es más que un conjunto ordenado de datos, con un significado específico, que son enviados desde un emisor hacia un receptor con la finalidad de transmitir un mensaje. Lógicamente, esta información contenida en un mensaje es utilizada por el receptor para tomar acciones sobre la base de su análisis.

¿Qué es la Seguridad de la Información?

La seguridad de la información no es más que el conjunto de medidas que deben de tomarse para proteger la información y evitar que pueda ser obtenida o adulterada por terceros no autorizados, ya sea mientras esté almacenada o cuando esté siendo transmitida.

Es necesario enfatizar que la información a la que se hace referencia aquí no es solamente la digital, almacenada en medios electrónicos, sino también la física, y que esta debe ser protegida igualmente de robos o adulteraciones.

Principios Básicos de la Seguridad

Principios Básicos de la Seguridad

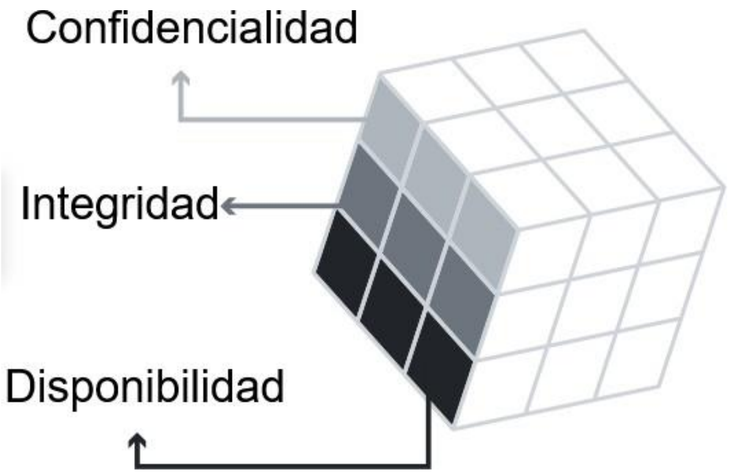
La seguridad de la información es un estado de bienestar de la información y la infraestructura en el que la posibilidad de robo, manipulación e interrupción de la información y los servicios es baja o tolerable

Principios Básicos de la Seguridad

Confidentiality (confidencialidad)

Es el hecho de que la información se mantenga privada, que no sea expuesta a terceros no involucrados en ella. Dicho de otra forma: un historial médico solamente debe ser conocido por el paciente y por el personal de salud que lo trata. Cualquier tercero (un familiar, un atacante del sistema del hospital, etcétera) que acceda a esta información estará violando el principio de confidencialidad.

Principios Básicos de la Seguridad



Integrity (integridad)

Este principio implica garantizar que la información no pueda ser adulterada o modificada por un tercero no autorizado, por ejemplo si alguien no autorizado entra al sistema de un banco y logra modificar los valores depositados en una cuenta para hacer que aparezca un valor mayor al que debía tener esta cuenta.

Principios Básicos de la Seguridad

Availability (disponibilidad)

Si la información no puede ser consultada por los interesados entonces no tiene mucho uso. Así, uno de los principios de la seguridad es garantizar que la información pueda ser consultada por los interesados cada vez que estos lo requieran. Este es un principio fundamental de la seguridad, pues muchas veces se dirigen los esfuerzos a vigilar que la información no sea adulterada (integridad) o que no se filtre (confidencialidad) y se descuidan los peligros que implica que la información no esté disponible.

Principios Básicos de la Seguridad

Autenticidad: implica que se pueda verificar que la información viene de quien dice ser su emisor. Esto es importante, pues un mensaje puede haber sido «forjado», creado por parte de un tercero no autorizado, con la finalidad de hacernos creer que vino de alguien en quien confiamos. La autenticidad tiene mucha relación con el segundo principio de la tríada CIA, la integridad. Debemos ser capaces de saber que la información que nos ha llegado no ha sido alterada (en este caso, «forjada») por un tercero.

No repudio: se trata de garantizar que quien haya participado en una comunicación no pueda posteriormente indicar que no lo hizo.

Presentación del Programa

Objetivo de la clase

Explicar los fundamentos de la seguridad de la información, en base a la triada de la información

Contenidos de la Clase

- ¿Qué es la Ciberseguridad o Seguridad Informática?
- Amenazas Actuales Ciberseguridad

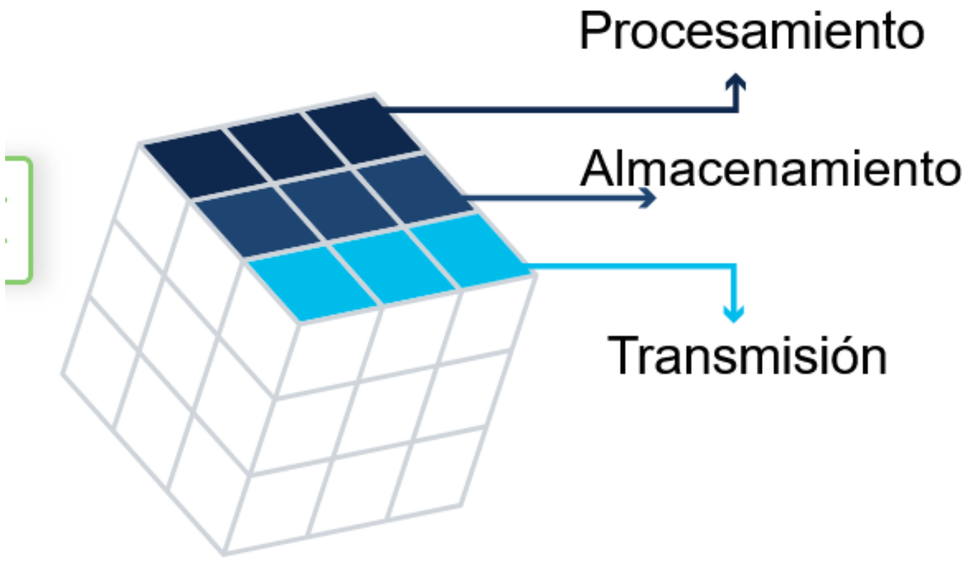
  - contra quien nos enfrentamos?

¿Qué es la Ciberseguridad o Seguridad Informática?

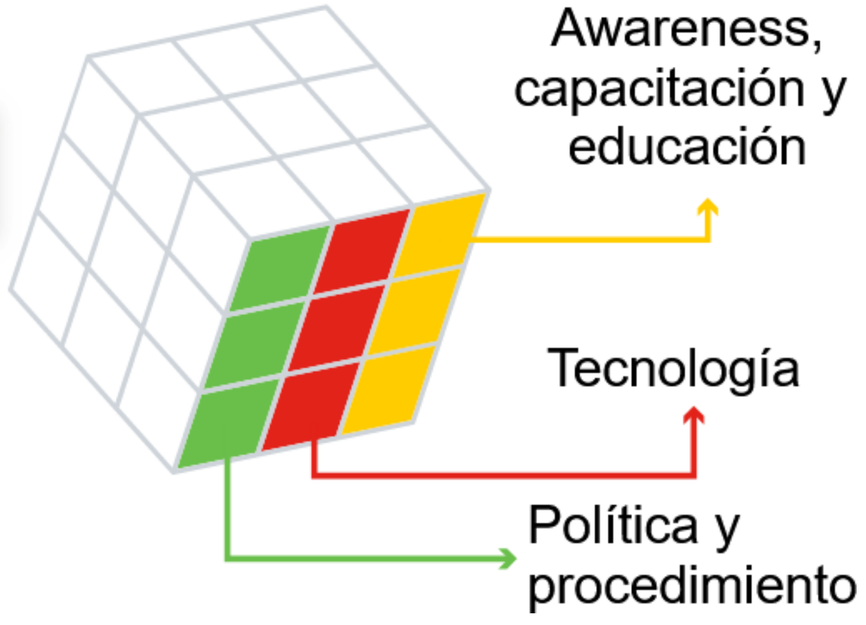
Entendemos por ciberseguridad aquellas estrategias y acciones que lleva a cabo una empresa o particular para proteger y defender sus activos digitales de posibles ataques cibernéticos, como robo de información y control de los dispositivos.

Se trata de una rama de la informática que cada vez es más necesaria puesto que nuestro nivel de conexión online es cada vez más alto y frecuente. Concretamente, los ciberataques son una amenaza constante a empresas de todos los tamaños.

La protección de información en cada estado



Las medidas de seguridad se utiliza para proteger los datos



Seguridad de la Información

Seguridad de la Información: Es el conjunto de medidas, políticas, prácticas y procedimientos que se implementan para proteger la información de accesos no autorizados, alteraciones, destrucción o pérdida, garantizando su confidencialidad, integridad y disponibilidad. La seguridad de la información no solo se refiere a la protección de sistemas informáticos, sino también a la gestión de datos en formatos físicos y digitales, involucrando tanto a personas como a procesos.

Seguridad Informática

Seguridad Informática: Hace referencia específicamente a la protección de los sistemas informáticos, incluidas las redes, dispositivos y software, frente a riesgos y amenazas que puedan comprometer la confidencialidad, integridad y disponibilidad de la información almacenada o procesada. Su enfoque está más centrado en la protección de los activos tecnológicos de una organización, como servidores, bases de datos, y redes, y en prevenir ataques como malware, intrusiones y otros tipos de vulnerabilidades.

Riesgos de Ciberseguridad

- *"Potencial de que una **amenaza** determinada explote las **vulnerabilidades** de los activos o grupos de activos causando así daño a la organización"* (ISO 27.000)

CID Negocio

Riesgo TI = Probabilidad x Impacto - Controles

Amenazas Vulnerabilidades

Amenazas Actuales Ciberseguridad

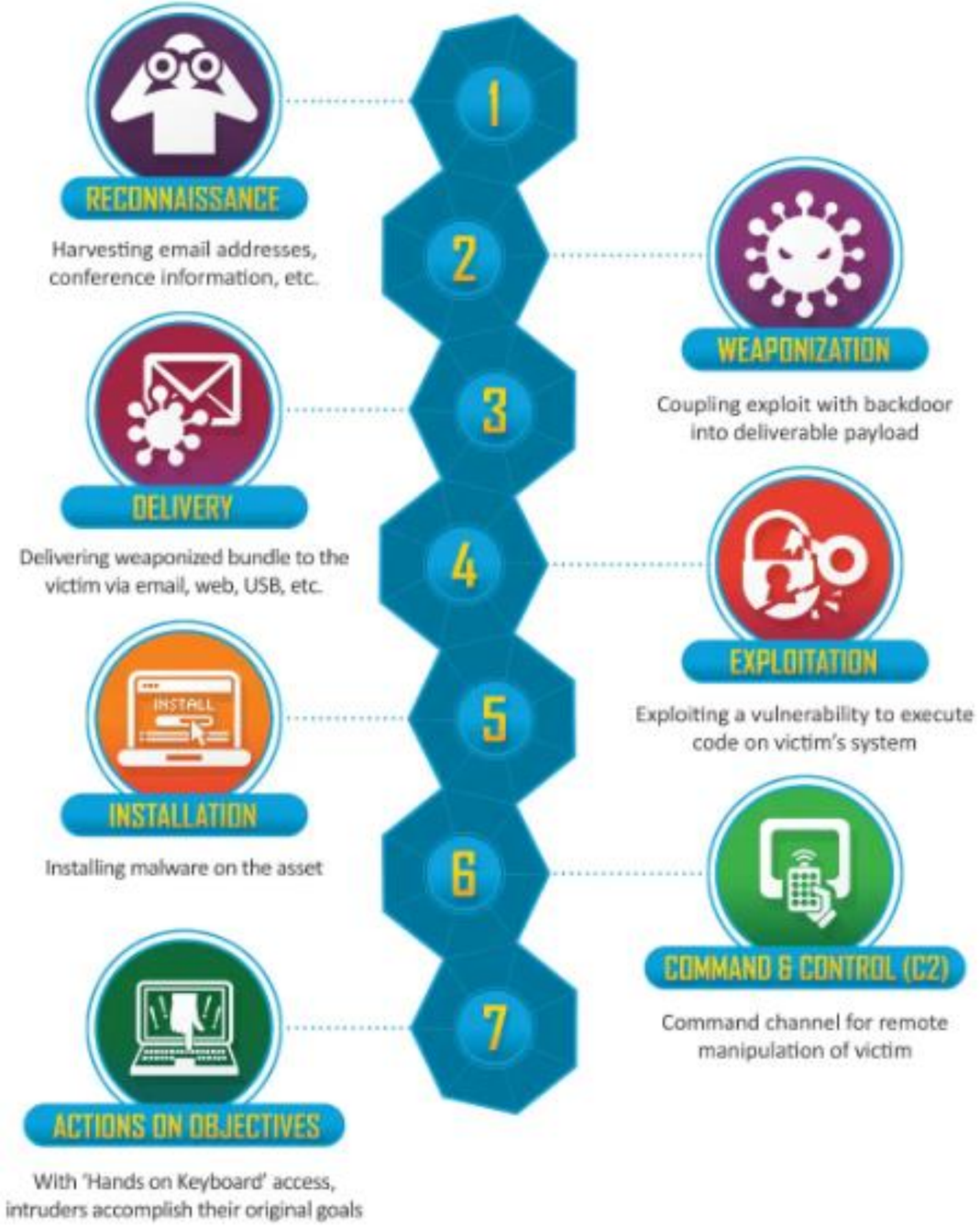
Amenazas

- "Causa potencial de un incidente no deseado, el cual puede ocasionar daño a un sistema o a una organización" (ISO 27000:2019)

- "Toda acción que aprovecha una vulnerabilidad para atentar contra la seguridad de un sistema de información" (INCIBE, 2019)

- Pueden ser desde un simple malware hasta sofisticados ciberataques, eventos naturales, la competencia empresarial, un empleado desvinculado, entre otros.

- Desde el punto de vista organizacional pueden ser tanto internas como externas.



Amenazas Actuales Ciberseguridad

Cyber Kill Chain, es un modelo que describe las etapas de un ciberataque. Este modelo ayuda a los equipos de seguridad a identificar y detener los ataques.

Vulnerabilidad

- "Debilidad de un activo o de un control que puede ser explotada por una o más amenazas" (ISO 27000:2019)

- "Es una debilidad o fallo en un sistema de información que pone en riesgo la seguridad de la información pudiendo permitir que un atacante pueda comprometer la integridad, disponibilidad o confidencialidad de la misma, por lo que es necesario encontrarlas y eliminarlas lo antes posible. " (INCIBE, 2019)

- "Debilidad de un activo o de un control que puede ser explotada por una o más amenazas"

Amenazas Actuales Ciberseguridad

Contra quien nos enfrentamos?

CINE

REALIDAD

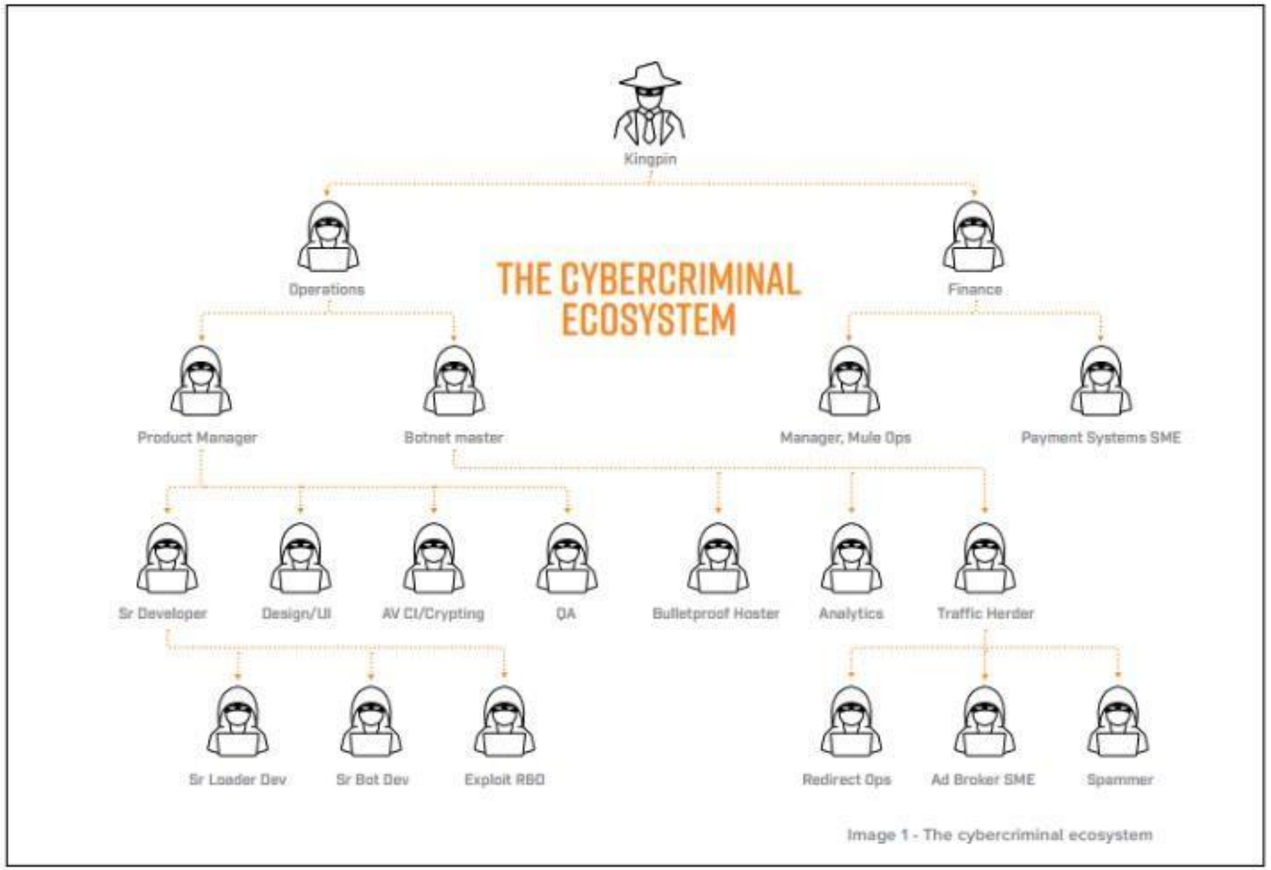


Image 1 - The cybercriminal ecosystem

Amenazas Actuales Ciberseguridad

Contra quien nos enfrentamos?

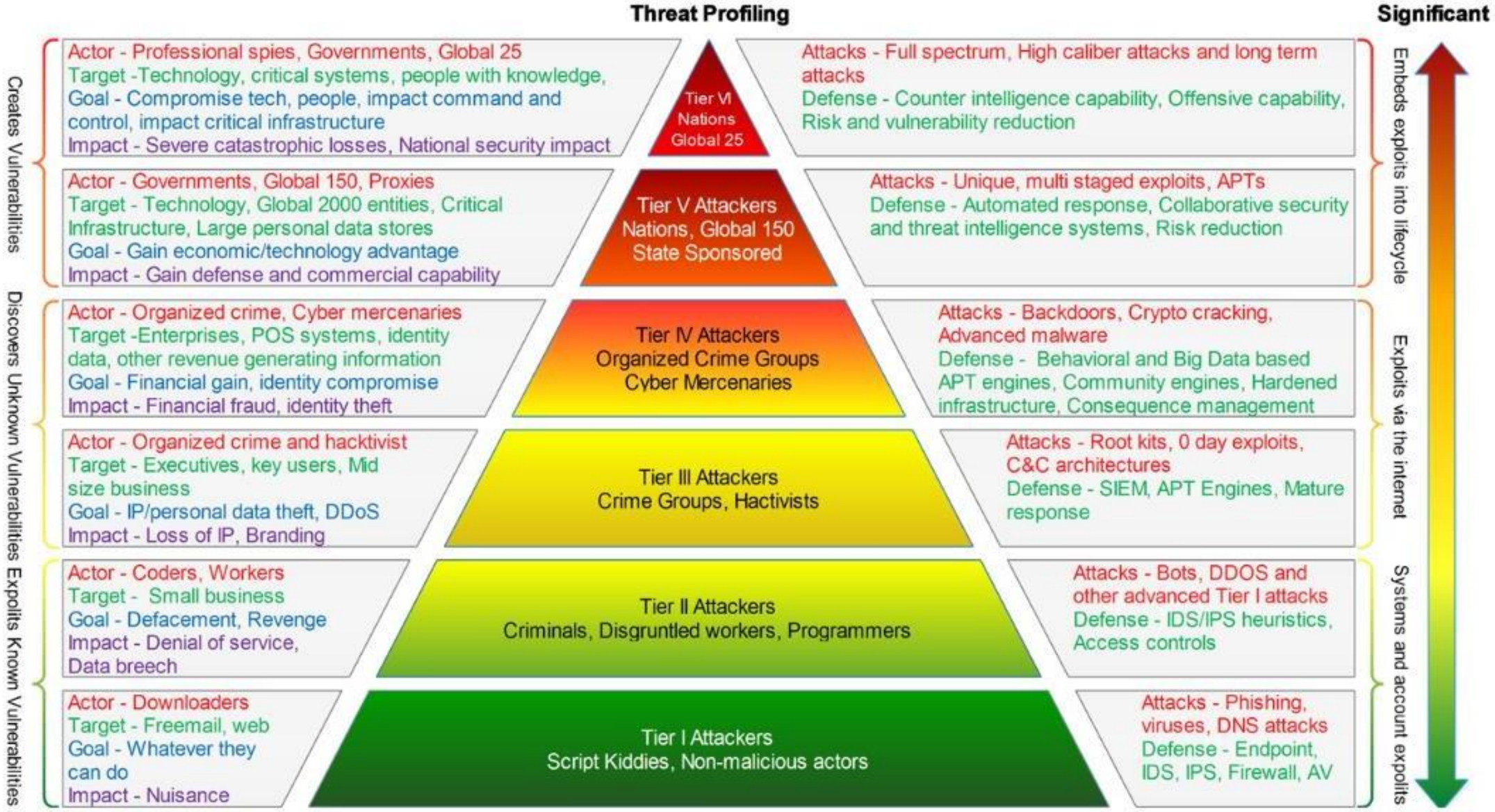
Delincuentes Comunes

Delincuentes Informáticos

Grupos Hacktivistas

Grupos APT

Amenazas Actuales Ciberseguridad



Amenazas Actuales Ciberseguridad

Hacemos todas las cosas bien?

Delincuentes Comunes	Delincuentes Informáticos	Grupos Hacktivistas	Grupos APT
APROVECHAN			
Desconocimiento de las personas Descuido de las personas Malas prácticas de ciberseguridad Contraseñas débiles Uso no seguro de dispositivos	Lo anterior + Equipos Obsoletos + Vulnerabilidades no parchadas + Falta de antivirus + Desarrollo de software no seguro	Lo anterior + Redes deficientes + Servidores no hardenizados + Servicios deficientes + Infraestructura no resiliente	Lo anterior + Sus altas capacidades + Creación de nuevo malware + Extorsión + Anonimato

Amenazas Actuales Ciberseguridad

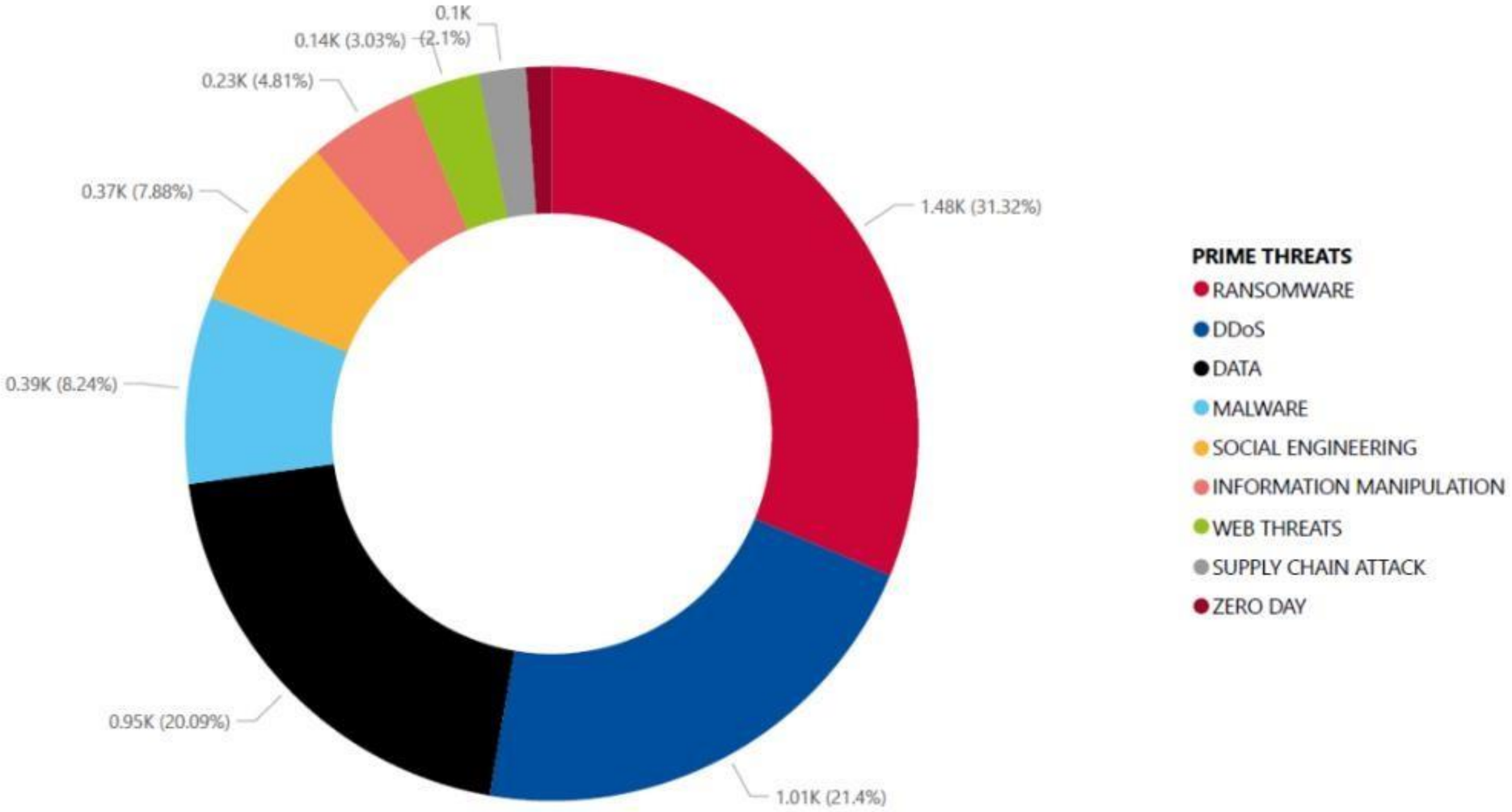
Amenazas – Lo más prioritario

enisa-threat-landscape-2023

- Malware
- Ingeniería Social
- Amenazas contra los datos
- Denegación de Servicios
- Manipulación de Información
- Ataques a la Cadena de Suministros
- Ransomware

Amenazas Actuales Ciberseguridad

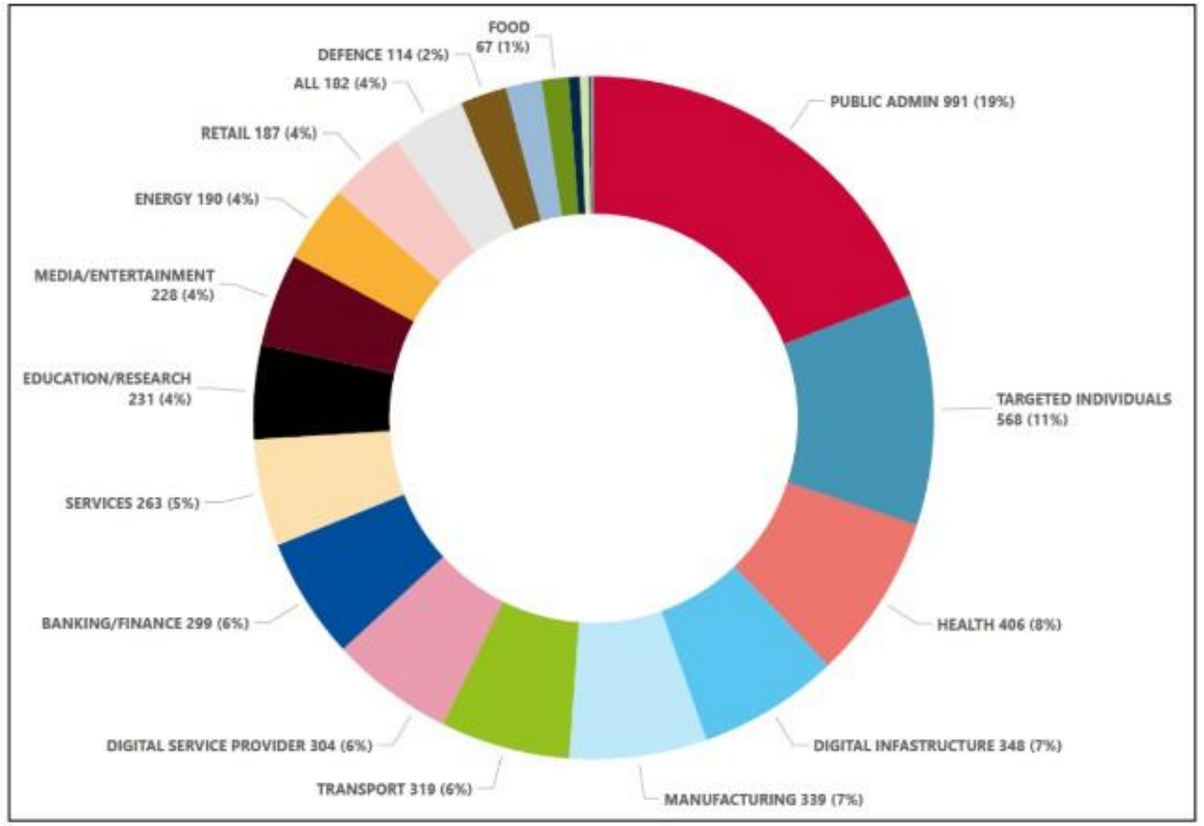
Principales Amenazas por Grupo

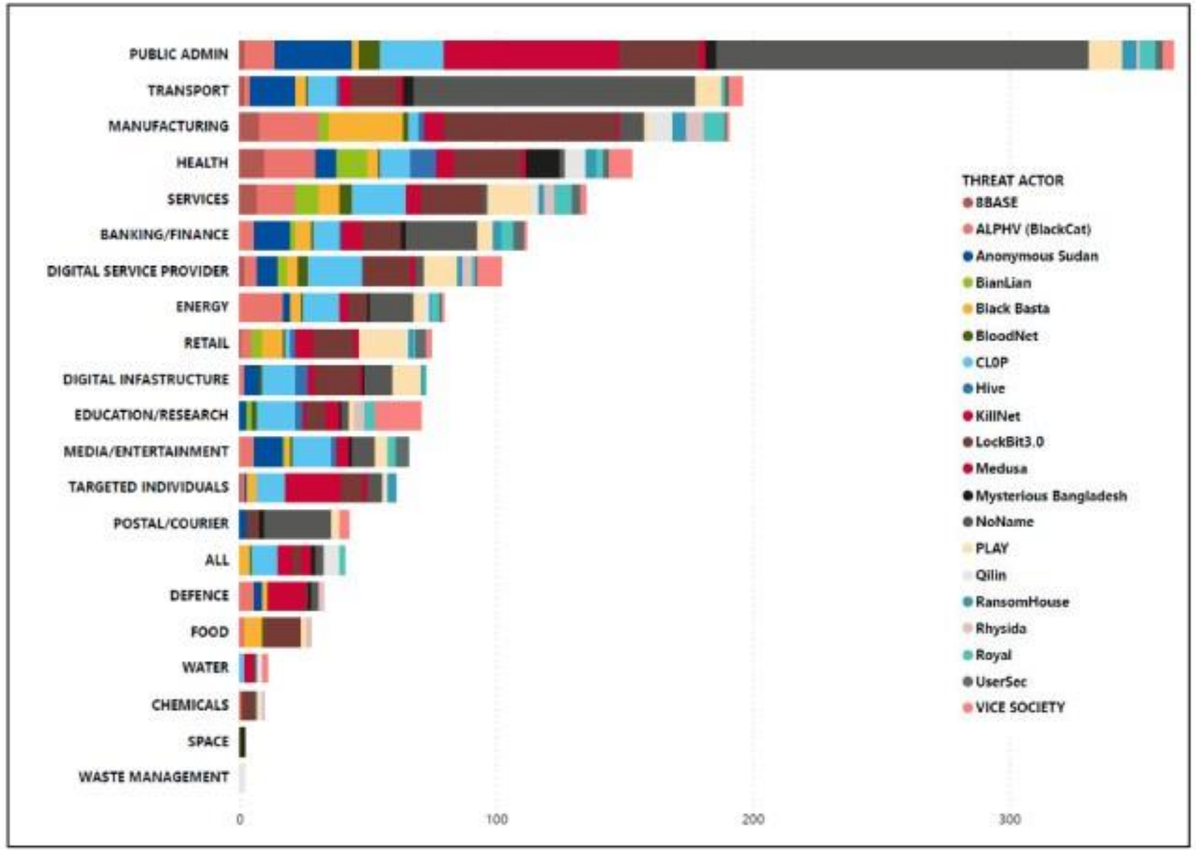


enisa-threat-landscape-2023

Amenazas Actuales Ciberseguridad

Principales Amenazas por Sector/Actor





Amenazas Actuales Ciberseguridad

Pasa en la Realidad en Hispanoamerica?

El ciberataque de ransomware a IFX Networks afecta a Colombia, Chile, Panamá y 762 empresas

El ciberataque de ransomware a IFX Networks afecta a decenas de servicios en Colombia, Chile, Panamá y a 762 empresas · Más de dos millones de...

Ataque ransomware al grupo GTD afecta organismos públicos y empresas de Chile y Perú

Ataque ransomware al grupo GTD afecta organismos públicos y empresas de Chile y Perú. El ransomware, conocido como Rorschach o BabLock, llama la...

Claro es víctima de ransomware que afectó su servicio celular en varios países de Centroamérica

A través de un breve comunicado, Claro confirmó que sufrió el ataque de un ransomware y que ya ha tomado medidas para contrarrestarlo.

La UBA sufrió un ciberataque de ransomware: docentes y alumnos no pueden acceder a los sistemas

Se trata de un programa malicioso que usan los ciberdelincuentes para encriptar archivos y pedir un rescate a la víctima.

Costa Rica no pagó a hackers, pero sí invirtió $25 millones para recuperar información de Hacienda y la CCSS

Si bien, considerando los desafíos económicos y éticos, país generó mensaje que refuerza importancia de ciberseguridad de cara al futuro.

Santander: el robo masivo de datos del banco que afecta a millones de clientes en Chile, Uruguay y España, y a todos sus empleados

Un grupo de piratas informáticos intenta vender lo que dicen es información confidencial perteneciente a millones de empleados y clientes...

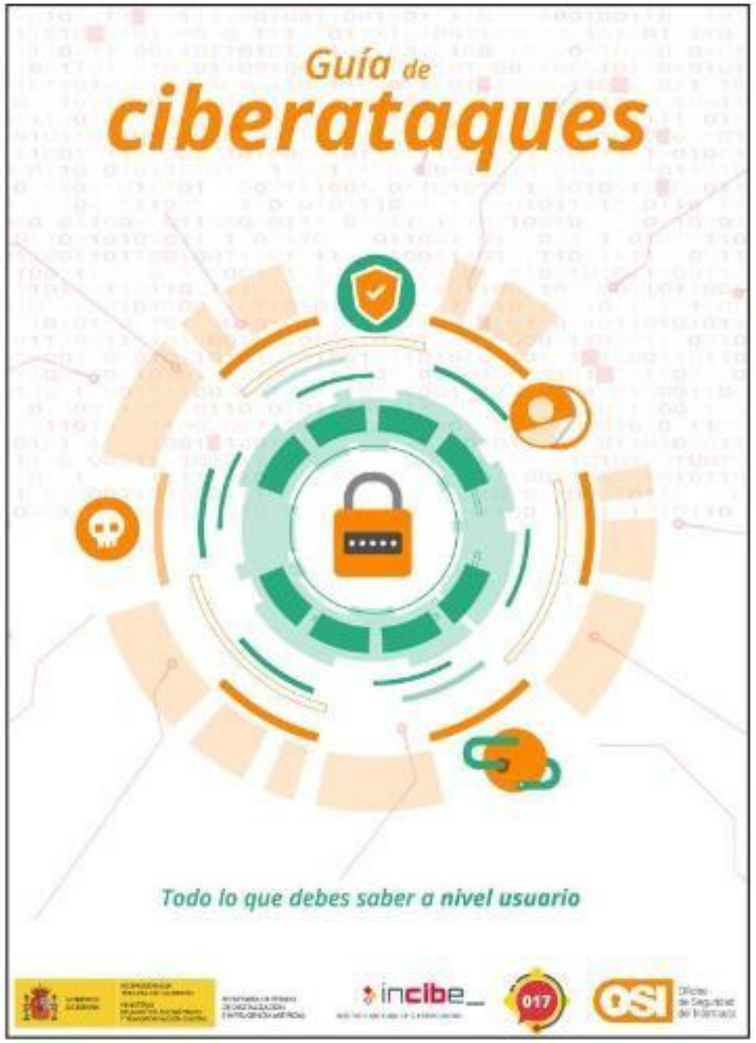
Ola de ciberataques en España: roban millones de datos a Iberdrola, Santander, DGT, Telefónica y Ticketmaster

La UE alerta que los 'asaltos' cibernéticos se han duplicado en 2024 y que no han dejado de aumentar desde la invasión de Ucrania.

¿Ciberataque al IECM comprometió resultado de elección en CDMX? Esto dicen consejeros

El ciberataque al portal de IECM no afectará el Programa de Resultados Electorales Preliminares, anunciaron los consejeros electorales de la CDMX.

Amenazas Actuales Ciberseguridad



Objetivos de los ciberataques y sus consecuencias para el usuario 03

Tipos de ciberataques

1 Ataques a contraseñas 04
1.1. Fuerza bruta 05
1.2. Ataque por diccionario 06

2 Ataques por ingeniería social 07
2.1. Phishing, Vishing y Smishing 08
2.2. Baiting o Gancho 10
2.3. Shoulder surfing o mirando por encima del hombro 11
2.4. Dumpster Diving o rebuscando en la basura 12
2.5. Spam o correo no deseado 13
2.6. Fraudes online 14

3 Ataques a las conexiones 15
3.1 Redes trampa (Wifi falsas) 16
3.2. Spoofing o suplantación 17
3.2.1 IP Spoofing 18
3.2.2 Web Spoofing 19
3.2.3 Email Spoofing 20
3.2.4 DNS Spoofing 21
3.3. Ataques a Cookies 22
3.4. Ataques DDoS 24
3.5. Inyección SQL 26
3.6. Escaneo de puertos 27
3.7. Man in the middle o ataque de intermediario 28
3.8. Sniffing 29

4 Ataques por malware 30
4.1. Virus 31
4.2. Adware o anuncios maliciosos 32
4.3. Spyware o software espía 33
4.4. Troyanos 34
4.4.1. Backdoors 35
4.4.2. Keyloggers 36
4.4.3. Stealers 37
4.4.4. Ransomware 38
4.5. Gusano 39
4.6. Rootkit 40
4.7. Botnets o redes zombi 41
4.9. Rogueware o el falso antivirus 42
4.10. Criptojacking 43
4.11. Apps maliciosas 44

Medidas de protección 45

https://www.incibe.es/ciudadania/formacion/guias/guia-de-ciberataques

Medidas de Protección

International Organization for Standardization

ISO

27002

CIS Controls
Version 8

01	Inventory and Control of Enterprise Assets
02	Inventory and Control of Software Assets
03	Data Protection
04	Secure Configuration of Enterprise Assets and
05	Account Management
06	Access Control Management
07	Continuous Vulnerability Management
08	Audit Log Management
09	Email and Web Browser Protections
10	Malware Defenses
11	Data Recovery
12	Network Infrastructure Management
13	Network Monitoring and Defense
14	Security Awareness and Skills Training
15	Service Provider Management
16	Application Software Security
17	Incident Response Management
18	Penetration Testing

MITRE ATT&CK™

ESTÁNDARES PARA LA SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD

GOBERNANZA

- COBIT 2019
- COSO
- ISO 38500 – Gobierno de TI
- ISO 27014 – Gobierno de la Seguridad de la Información

GESTIÓN DE RIESGOS

- ISO 27005 – Gestión de Riesgos de TI
- ISO 31000 – Gestión de Riesgos
- COSO
- NIST 800-37 Risk Management

AUDITORÍA

- ISO 19011 – Directrices auditoría de Sistemas de Gestión
- ISO 27007 – Auditoría al SGSI
- GTAG – The IIA Guías de Auditoría y Tecnología Global

GOBIERNO DE DATOS

- ISO 25012 – Modelo de Calidad de Datos
- DAMA-DMBOK
- ISO 27037 – Evidencia Electrónica

CONTROLES DE SI

- ISO 27002 – Controles de SI
- CIS Controls
- NIST 800-53 Controles de Seguridad y Privacidad

CLOUD COMPUTING

- ISO 27017 – Seguridad en cloud Computing
- CSA STAR
- ISO 27018 – Protección de información personal en la nube

CIBERSEGURIDAD

- ISO 27032 – Controles de Ciberseguridad
- ISO 27103 – Ciberseguridad y estándares ISO
- NIST Framework de Ciberseguridad
- NIST 800-82 Seguridad e Sistemas de Control Industrial
- NIST 8228 Riesgos de Ciberseguridad y privacidad en IoT

PRIVACIDAD

- ISO 27701 – Gestión de la Privacidad de la Información
- ISO 27018 – Protección de información personal en la nube
- NIST Framework de Privacidad
- NIST 800-122 Protección de información personal

GESTIÓN DE INCIDENTES

- ISO 27035-1 – Gestión de Incidentes de SI
- ISO 27035-2 – Directrices para la implementación
- NIST 800-61 Guía para la Gestión de Incidentes
- KASPERSKY lab – INCIDENT RESPONSE GUIDE

SEGURIDAD SOFTWARE

- ISO 27034 – Seguridad en Aplicaciones
- OWASP

GESTIÓN DE SERVICIOS PROYECTOS/PROVEEDORES

- ITIL
- A GUIDE TO THE PROJECT MANAGEMENT BODY OF KNOWLEDGE PMBOK GUIDE
- COBIT 2019

CONTINUIDAD DEL NEGOCIO

- ISO 22301 – Gestión de la Continuidad del Negocio
- ISO 22313 – Directrices para la implementación
- NIST 800-34 Guía para planificación de contingencia
- bci Good Practice Guidelines

Information Security Management – ISO 27001 – Certified

- ISO 27001: Gestión de la Seguridad de la Información. Protege datos sensibles. 🔴📄
- ISO 27002: Mejores prácticas de seguridad. Guía para implementar controles. 📚✅
- ISO 27005: Gestión de riesgos en seguridad de la información. ⚠️📊
- ISO 27017: Seguridad en la nube. ☁️🔒
- ISO 27018: Protección de datos personales en la nube. 🕵️☁️
- ISO 22301: Continuidad del negocio ante interrupciones. 🔄🏢
- ISO 27032: Ciberseguridad global y colaboración. 🌍🤝

ISO 27001
Reducir el riesgo de violaciones de la seguridad en el entorno informático.
Confidencialidad de la información
Minimización de los riesgos informáticos, los posibles daños y los costes derivados.
Ventaja competitiva gracias a un punto de referencia reconocido
Mayor confianza con los socios, los clientes y el público
Un método estructurado para cumplir los requisitos de conformidad
Cumplimiento de los requisitos reconocidos internacionalmente
Detección sistemática de vulnerabilidades
Costes más bajos
Control del riesgo informático

ISO 27001

La ISO 27001 es un estándar internacional para la implementación de un Sistema de Gestión de la Seguridad de la Información (SGSI), que proporciona un marco para gestionar la seguridad de la información de una organización de manera sistemática.

ISO 27001

Sistema de gestión de seguridad de la información

Contexto de la organización

Es fundamental que la organización comprenda su entorno, tanto interno como externo, y sus partes interesadas (empleados, clientes, proveedores, autoridades regulatorias, etc.). Esto ayudará a determinar las necesidades y expectativas en cuanto a la seguridad de la información.

Análisis del contexto: Identificación de factores internos y externos que puedan afectar el SGSI.

Identificación de las partes interesadas: Determinación de los requisitos y expectativas de las partes interesadas relevantes.

Alcance del SGSI: Definición clara de qué áreas, procesos y activos estarán cubiertos por el SGSI.

Liderazgo y compromiso de la dirección

El liderazgo efectivo es un aspecto fundamental para el éxito de la implementación de un SGSI. La alta dirección debe demostrar su compromiso con la seguridad de la información y liderar el proceso de implementación.

Política de seguridad de la información: La alta dirección debe establecer una política clara de seguridad de la información que esté alineada con los objetivos estratégicos de la organización.

Responsabilidad y autoridad: La dirección debe asignar roles y responsabilidades claras para la implementación, mantenimiento y mejora continua del SGSI.

Evaluación de riesgos

Uno de los requisitos más importantes es la identificación, evaluación y tratamiento de los riesgos relacionados con la seguridad de la información. La organización debe llevar a cabo un análisis de riesgos para identificar amenazas y vulnerabilidades que puedan afectar la confidencialidad, integridad y disponibilidad de la información.

Identificación de riesgos: Reconocer los riesgos que afectan a los activos de información.

Evaluación de riesgos: Evaluar la probabilidad de que ocurran estos riesgos y sus impactos en la organización.

Tratamiento de riesgos: Determinar las medidas de seguridad necesarias para mitigar, transferir o aceptar los riesgos identificados.

Objetivos de seguridad de la información

La organización debe definir objetivos específicos de seguridad de la información que sean medibles y alineados con los objetivos estratégicos de la empresa. Los objetivos deben ser revisados y ajustados periódicamente.

Definición de objetivos claros y medibles: Establecer metas para garantizar la confidencialidad, integridad y disponibilidad de la información.

Revisión y evaluación: Realizar revisiones periódicas para asegurar el cumplimiento de los objetivos establecidos.

Recursos y apoyo

La implementación de un SGSI requiere la asignación de recursos adecuados, incluyendo tiempo, personal, tecnología y presupuesto. Además, el personal debe estar capacitado para cumplir con los procedimientos y políticas establecidas.

Asignación de recursos: La organización debe asegurarse de contar con los recursos necesarios para implementar y mantener el SGSI.

Capacitación y concientización: El personal debe ser capacitado y concienciado sobre la importancia de la seguridad de la información y sus responsabilidades.

Planificación y control de la implementación

La implementación de un SGSI debe ser planificada cuidadosamente para garantizar que se logren los objetivos establecidos. El plan debe incluir plazos, responsables, actividades y recursos necesarios.

Desarrollo de un plan de implementación: Planificar las acciones, responsables y plazos para la implementación del SGSI.

Monitoreo y control: Realizar un seguimiento continuo para garantizar que las actividades se realicen de acuerdo con lo planeado y que los resultados sean los esperados.

Gestión de incidentes de seguridad de la información

La organización debe establecer procedimientos para detectar, gestionar y responder a incidentes de seguridad de la información, con el fin de minimizar su impacto.

Gestión de incidentes: Implementar un proceso para identificar, analizar y responder a los incidentes de seguridad.

Lecciones aprendidas: Después de cada incidente, se deben extraer lecciones y actualizar los controles y procedimientos para prevenir futuros problemas.

Evaluación del desempeño y auditorías internas

Es necesario realizar auditorías internas periódicas para evaluar la eficacia del SGSI y asegurar que cumple con los requisitos de la ISO 27001.

Auditorías internas: Programar y realizar auditorías internas para verificar que se cumplan las políticas, procedimientos y controles de seguridad de la información.

Revisión de la dirección: La alta dirección debe revisar regularmente el desempeño del SGSI para identificar áreas de mejora.

Mejora continua

El proceso de mejora continua es fundamental en la ISO 27001. La organización debe estar comprometida a mejorar constantemente su SGSI para abordar nuevos riesgos y adaptarse a los cambios en el entorno y la tecnología.

Acción correctiva y preventiva: La organización debe establecer mecanismos para corregir las no conformidades y prevenir que se repitan.

Revisión y ajustes del SGSI: Se deben realizar mejoras en base a los resultados de las auditorías internas, las revisiones de la dirección, y el análisis de incidentes.

Documentación y registros

Un SGSI conforme a la ISO 27001 requiere una adecuada documentación y registro de todos los procesos relacionados con la gestión de la seguridad de la información.

Documentación del SGSI: La política de seguridad de la información, los procedimientos, los resultados de las auditorías, y otros documentos deben ser apropiadamente documentados.

Registros de tratamiento de riesgos y controles: Se deben mantener registros detallados sobre las evaluaciones de riesgos, las medidas de tratamiento y la eficacia de los controles.

ISO 27001
COMPLIANCE STEPS
1
ORGANIZATIONAL CONTEXT
2
SCOPE
3
LEADERSHIP
4
PLANNING
5
SUPPORT
6
OPERATIONS
7
PERFORMANCE EVALUATION
8
IMPROVEMENT

Cumplimiento de la norma ISO 27001

Finalmente, para obtener la certificación, la organización debe demostrar que cumple con los requisitos establecidos en la norma ISO 27001 mediante una evaluación externa realizada por una entidad certificadora acreditada.

La ISO/IEC 27001 se compone de una serie de cláusulas que describen los requisitos para implementar un Sistema de Gestión de la Seguridad de la Información (SGSI). Estas cláusulas son fundamentales para que una organización pueda cumplir con los requisitos establecidos por la norma y, si lo desea, obtener la certificación ISO 27001.

Cláusulas de la ISO/IEC 27001:

La norma ISO 27001 está estructurada en 10 cláusulas, las cuales se enumeran a continuación:

Cláusula 1: Alcance

Esta cláusula describe el alcance de la norma, incluyendo el propósito de establecer y mantener un SGSI para proteger la información y los activos de la organización.

Cláusula 2: Normas y documentos de referencia

Se refiere a las normas relacionadas y los documentos de referencia utilizados en la implementación de la ISO 27001, como la ISO/IEC 27002 (código de buenas prácticas de seguridad de la información).

Cláusula 3: Términos y definiciones

Define los términos clave utilizados en la norma ISO 27001, como "SGSI", "seguridad de la información", "riesgo", entre otros.

Cláusula 4: Contexto de la organización

Establece la necesidad de que la organización comprenda su contexto (externo e interno), las partes interesadas y sus necesidades y expectativas, para definir el alcance y los objetivos del SGSI.

Cláusula 5: Liderazgo

Requiere que la alta dirección demuestre liderazgo y compromiso con la seguridad de la información. Esto incluye la creación de una política de seguridad, asignación de responsabilidades y apoyo al SGSI.

Cláusula 6: Planificación

En esta cláusula, la organización debe realizar un análisis de riesgos, definir objetivos de seguridad y planificar las acciones necesarias para alcanzar esos objetivos, teniendo en cuenta los riesgos identificados.

Cláusula 7: Soporte

Describe los recursos necesarios para implementar el SGSI, incluida la asignación de personal capacitado, tecnología, presupuestos y la gestión del conocimiento. También establece la necesidad de crear una cultura organizacional enfocada en la seguridad de la información.

Cláusula 8: Operación

Define la implementación de los planes de acción para gestionar los riesgos identificados y alcanzar los objetivos de seguridad de la información. Además, se refiere al monitoreo y control de los procesos operativos.

Cláusula 9: Evaluación del desempeño

La organización debe realizar un seguimiento continuo del desempeño del SGSI mediante auditorías internas, medición de resultados y revisión de la alta dirección para asegurar que el SGSI sea eficaz y cumpla con los requisitos establecidos.

Cláusula 10: Mejora

En esta cláusula, se requiere que la organización implemente un proceso de mejora continua, gestionando las no conformidades y tomando acciones correctivas y preventivas para optimizar el SGSI.

Requisitos Obligatorios para la Certificación ISO 27001:

Para obtener la certificación ISO 27001, la organización debe cumplir con varios requisitos obligatorios que se encuentran a lo largo de las cláusulas. A continuación, se detallan los requisitos obligatorios que son esenciales para la certificación:

Cláusula 4: Contexto de la organización

Debe identificarse el contexto interno y externo de la organización, las partes interesadas y sus expectativas, y debe definirse el alcance del SGSI.

Cláusula 5: Liderazgo

La alta dirección debe demostrar liderazgo, comprometerse con el SGSI, aprobar la política de seguridad de la información y garantizar la asignación de roles y responsabilidades.

Cláusula 6: Planificación

La organización debe realizar una evaluación de riesgos y tratamiento de los mismos, establecer objetivos de seguridad de la información y planificar la forma de alcanzarlos. La planificación incluye identificar y evaluar riesgos de seguridad de la información.

Cláusula 7: Soporte

La organización debe asegurar la disponibilidad de recursos necesarios, incluir la capacitación del personal en seguridad de la información y garantizar la documentación adecuada del SGSI.

Cláusula 8: Operación

La implementación de los controles definidos para mitigar los riesgos debe ser efectiva. La organización debe poner en marcha los procedimientos y controles necesarios para tratar los riesgos identificados.

Cláusula 9: Evaluación del desempeño

Se requiere que la organización realice auditorías internas, realice revisiones de desempeño del SGSI y garantice que el SGSI está siendo operado de manera efectiva.

Cláusula 10: Mejora

La organización debe asegurarse de que existen mecanismos para la mejora continua, como la corrección de no conformidades, la implementación de acciones preventivas y la actualización del SGSI.

Aunque todas las cláusulas de la ISO 27001 son importantes para implementar un SGSI eficaz, las cláusulas 4 a 10 son esenciales para la certificación. Esto se debe a que cubren todos los aspectos clave del SGSI, desde el análisis del contexto organizacional y la planificación, hasta la evaluación del desempeño y la mejora continua.

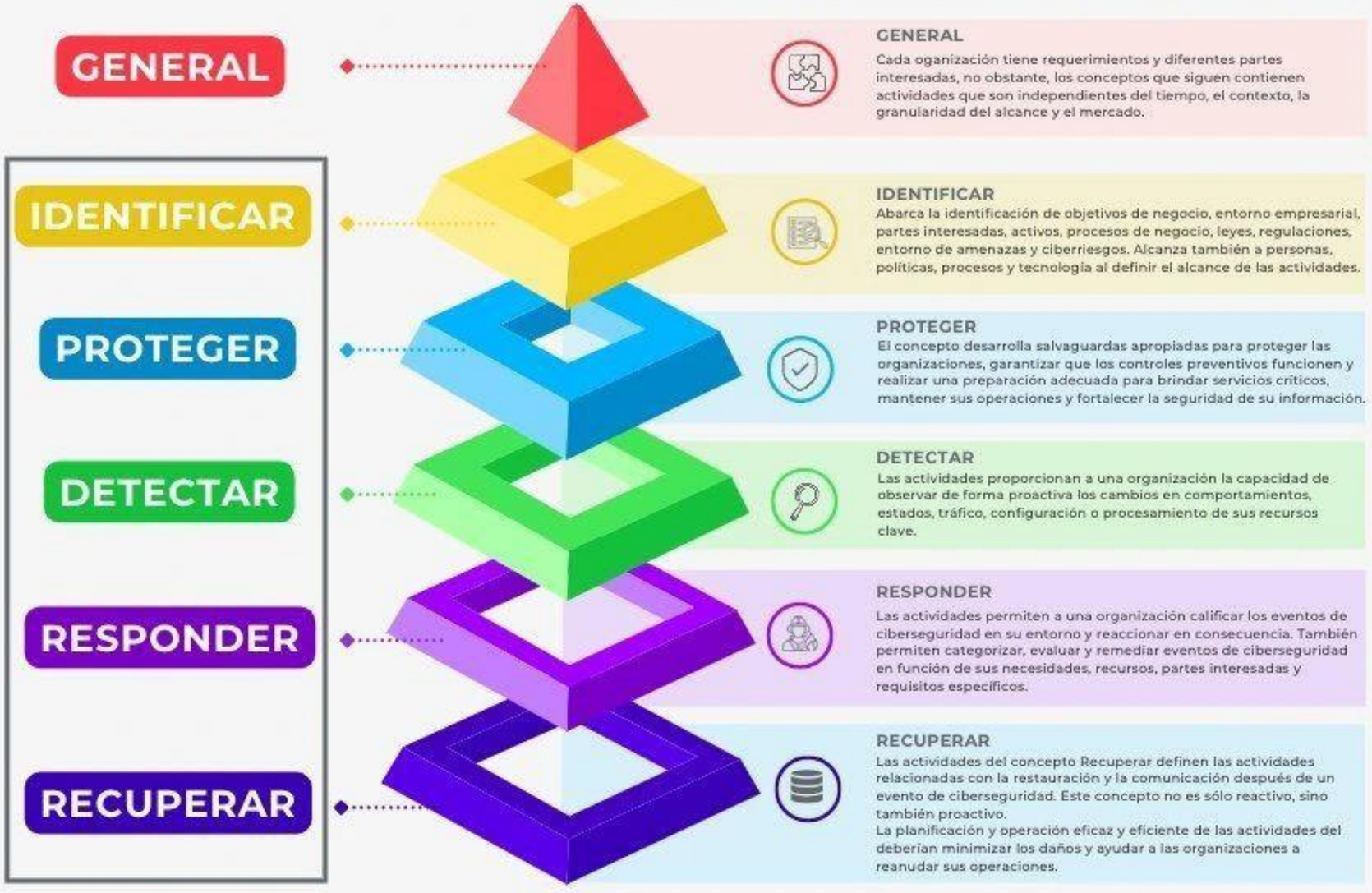
Para obtener la certificación ISO 27001, una organización debe implementar y documentar todos estos requisitos, demostrar su cumplimiento mediante auditorías internas y externas, y asegurar que el SGSI se mantenga actualizado y en funcionamiento durante todo el ciclo de vida.

ISO 27001

11 Domains of ISO 27001

ISO/IEC 27002: 2022. Los 5 conceptos son atributos de los 93 controles.

La explicación de los conceptos se encuentra en ISO/IEC 27110: 2021 Tecnología de la información, ciberseguridad y protección de la privacidad: directrices para el desarrollo del marco de ciberseguridad.



Conceptos clave

ISO/IEC 27002:2022

93 Controles de Seguridad de la información, ciberseguridad y protección de la privacidad.

4 Dominios de seguridad

GOBIERNO Y ECOSISTEMA

- GOBIERNO DE SEGURIDAD DE LA INFORMACIÓN & GESTIÓN DEL RIESGO
- GESTIÓN DE LA CIBERSEGURIDAD DEL ECOSISTEMA (INCLUYE PARTES INTERESADAS INTERNAS Y EXTERNAS)

PROTECCIÓN

- ARQUITECTURA DE SEGURIDAD DE TI
- ADMINISTRACIÓN DE SEGURIDAD DE TI
- GESTIÓN DE ACCESOS E IDENTIDADES
- MANTENIMIENTO DE LA SEGURIDAD DE TI
- SEGURIDAD FÍSICA Y MEDIOAMBIENTAL

DEFENSA

- DETECCIÓN
- GESTIÓN DE INCIDENTES DE SI

RESILIENCIA

- GESTIÓN DE CRISIS
- CONTINUIDAD DE LAS OPERACIONES

#ISO27002_Dominios de seguridad _V02 @Marce_I_P

Controles de Seguridad Basados en CIS Controls

Los CIS Controls (Center for Internet Security Controls) son un conjunto de acciones prácticas diseñadas para mejorar la seguridad cibernética de las organizaciones. Seleccionar controles adecuados implica analizar la problemática específica y determinar cuáles de los 18 controles principales se aplican para mitigar los riesgos.

1. Identificación de la Problemática

Ejemplo de problemática: Un ataque de ransomware afecta a una organización debido a la falta de controles en el acceso a sistemas críticos y en la detección de comportamientos anómalos.

Aspectos clave de la problemática:

- Falta de segmentación en la red.
- Ausencia de políticas de respaldo y recuperación de datos.
- Vulnerabilidades en software no actualizado.
- Poca visibilidad de eventos sospechosos.

2. Selección de Controles Relevantes

Basándonos en la problemática, se pueden aplicar los siguientes controles de CIS:

1. Inventario y Control de Activos

Identificar y mantener un inventario actualizado de todos los dispositivos y sistemas conectados a la red.

Asegurar que solo dispositivos autorizados accedan a los sistemas críticos.

2. Inventario y Control de Software

Mantener un registro actualizado del software instalado.

Asegurar que solo se ejecuten aplicaciones aprobadas mediante listas blancas.

3. Gestión Continua de Vulnerabilidades

Realizar evaluaciones regulares de vulnerabilidades.
Aplicar parches y actualizaciones de seguridad de manera oportuna.

5. Uso Controlado de Permisos Administrativos

Limitar el acceso administrativo a sistemas críticos solo a personal autorizado.
Implementar el principio de privilegio mínimo.

6. Mantenimiento, Monitoreo y Análisis de Registros de Auditoría

Configurar sistemas para registrar eventos relevantes, como accesos fallidos o transferencias de datos inusuales.
Implementar herramientas de análisis de registros para identificar actividades sospechosas.

7. Protección contra Malware

Utilizar software de detección de malware en todos los dispositivos.
Configurar sistemas para bloquear sitios web maliciosos.

8. Copias de Seguridad de Datos

Implementar políticas de respaldo frecuentes de los datos críticos.
Probar regularmente los mecanismos de restauración para garantizar la recuperación en caso de ataque.

9. Seguridad en la Configuración de Redes

Dividir la red en segmentos para aislar sistemas críticos y limitar el movimiento lateral de los atacantes.
Implementar listas de control de acceso (ACL) para restringir el tráfico.

13. Protección de Datos

Clasificar los datos según su sensibilidad y aplicar controles adecuados.
Implementar cifrado para proteger datos en tránsito y en reposo.

15. Respuesta a Incidentes

Desarrollar y probar un plan de respuesta a incidentes.
Implementar procesos para contener, erradicar y recuperar sistemas afectados.

17. Capacitación en Conciencia de Seguridad

Entrenar al personal sobre prácticas seguras, como identificar correos electrónicos de phishing y reportar comportamientos sospechosos.

3. Aplicación de Controles

Una vez identificados los controles relevantes, sigue estos pasos para aplicarlos:

Evaluar el estado actual:

Determinar qué controles ya están implementados y cuáles necesitan mejoras.

Priorizar:

Dar prioridad a los controles que aborden los riesgos más críticos (por ejemplo, inventario, segmentación y copias de seguridad).

Desarrollar un plan de acción:

Asignar recursos y definir un cronograma para implementar los controles.

Medir y monitorear:

Establecer indicadores clave de rendimiento (KPIs) para evaluar la efectividad de los controles.

4. Ejemplo de Implementación

Problemática específica: Una empresa sufre ataques frecuentes de ransomware.
Controles seleccionados:

CIS Control 8 (Copias de Seguridad de Datos): Configurar respaldos automáticos diarios y almacenarlos en ubicaciones aisladas.

CIS Control 6 (Monitoreo de Registros): Implementar herramientas como SIEM para detectar comportamientos inusuales.

CIS Control 3 (Gestión de Vulnerabilidades): Realizar un escaneo semanal para identificar y parchear software vulnerable.

CIS Controls Version 7

01	Inventory of Hardware
02	Inventory of Software
03	Continuous Vulnerability Management
04	Control of Admin Privileges
05	Secure Configuration
06	Maintenance and Analysis of Logs
07	Email and Browser Protections
08	Malware Defenses
09	Limitation of Ports and Protocols
10	Data Recovery
11	Secure Configuration of Network Devices
12	Boundary Defense
13	Data Protection
14	Controlled Access Based on Need to Know
15	Wireless Access Control
16	Account Monitoring and Control
17	Security Awareness Training
18	Application Security
19	Incident Management
20	Penetration Testing

CIS Controls Version 8

01	Inventory and Control of Enterprise Assets
02	Inventory and Control of Software Assets
03	Data Protection
04	Secure Configuration of Enterprise Assets and
05	Account Management
06	Access Control Management
07	Continuous Vulnerability Management
08	Audit Log Management
09	Email and Web Browser Protections
10	Malware Defenses
11	Data Recovery
12	Network Infrastructure Management
13	Network Monitoring and Defense
14	Security Awareness and Skills Training
15	Service Provider Management
16	Application Software Security
17	Incident Response Management
18	Penetration Testing

CIS Center for Internet Security®

UNIVERSIDAD CATOLICA DE LA SANTISIMA CONCEPCION

UCSC